

API Scopes

لما نستخدم API Authentication ، بنقدر نعطي كل مستخدم أو Token صلاحيات مختلفة حسب الحاجة. هاي الصلاحيات اسمها **API Scopes** أو **Abilities** في Laravel Sanctum. فمثلاً ممكن نعطي Token صلاحية قراءة البيانات فقط، أو صلاحية إنشاء وتعديل وحذف البيانات. ولما يوصل أي Request ، Laravel بيتأكد إذا ال Token معه الصلاحية المطلوبة قبل ما يسمح بتنفيذ العملية، وهاي بنزيد أمان ال API وبنمنع أي مستخدم من تنفيذ عمليات مش مسموحة إله.

Rate Limiting

لما يكون ال API متاح لأي تطبيق أو مستخدم، ممكن حدا بيعت عدد كبير جداً من الطلبات خلال وقت قصير، وهذا ممكن يسبب ضغط على السيرفر أو يستخدم في هجمات مثل **Brute Force** عشان هايك Laravel بيوفر **Rate Limiting**، وهي ميزة بتحدد عدد الطلبات المسموح فيها خلال فترة زمنية معينة. وإذا المستخدم تجاوز العدد المسموح، السيرفر يرجع response تطلب منه ينتظر قبل ما يرسل طلبات جديدة.

CORS Configuration

لما يكون ال Frontend وال Backend موجودين على دومينات أو Ports مختلفة، المتصفح بمنع إرسال الطلبات بينهم بشكل مباشر لأسباب أمنية. هنا بيجي دور **CORS (Cross-Origin Resource Sharing)**، وهو المسؤول عن تحديد أي مواقع أو تطبيقات مسموح إلهما تتواصل مع ال API في Laravel بنقدر نحدد الدومينات المسموح إلهما، وأنواع الطلبات مثل **GET** و **POST** و **PUT** و **DELETE**، وكمان الهيدرز المسموح إرسالها. هايك الطلبات بتوصل من المصادر المصرح إلهما فقط.

API Security

حماية ال API ما بتعتمد على تسجيل الدخول فقط، وإنما على أكثر من خطوة بتشتغل مع بعض. أول إشي بنستخدم **Laravel Sanctum** لإنشاء وحماية ال Tokens ، وبعدها المستخدم بيعت **Bearer Token** مع كل Request حتى Laravel بيتأكد من هويته. كمان بنعمل **Validation** للبيانات قبل تنفيذ أي عملية عشان نتأكد إنها صحيحة، وبنستخدم **Rate Limiting** عشان نمنع إرسال عدد كبير من الطلبات خلال وقت قصير، وبنحدد الصلاحيات باستخدام **API Scopes** حتى كل Token يقدر ينفذ العمليات المسموح إله فيها فقط. ولزيادة الأمان، يفضل استخدام **HTTPS** حتى تبقى البيانات محمية أثناء انتقالها بين المستخدم والسيرفر.